ADMINISTRATION SYSTÈME

# Rapport d'Audit & Défense Réseau

*Mission de Sécurité - Segment 192.168.56.0/24*

| | |
|---|---|
| **Intervenant** | **FAROYAN Malchaz** |
| **Segment** | **192.168.56.0/24** |
| **Cible** | **192.168.56.101** |
| **Programme** | **BTS SIO - Sécurité Réseau** |

**Synthèse des livrables :**

| Phase | Livrable | Points |
|---|---|---|
| Reconnaissance | Analyse locale des ports + Validation IP | 4 pts |
| Audit Profond | Démasquage du service via analyse de version | 6 pts |
| Analyse / Veille | Justification du danger (Sources documentées) | 4 pts |
| Remédiation | Filtrage réseau validé (Scan & PuTTY) | 6 pts |

# Partie I - Reconnaissance (4 pts)

## 1.1 - Objectif

La première étape consiste à observer le serveur de l'intérieur pour comprendre sa configuration réseau. L'outil ss -tunlp liste tous les ports TCP et UDP en écoute sur la machine cible.

## 1.2 - Commandes exécutées

```
ip -c a
ss -tunlp
```

## 1.3 - Résultat

```
user@srv-deb-telnet:~$ ip -c a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:cc:42:d2 brd ff:ff:ff:ff:ff:ff
    altname enx080027cc42d2
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute enp0s3
       valid_lft 589sec preferred_lft 589sec
    inet6 fe80::a00:27ff:fecc:42d2/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

*La machine cible se trouve sur le réseau 192.168.56.0/24 avec l'adresse IP 192.168.56.101.*

| Port | Service standard | Service détecté | Niveau de risque |
|---|---|---|---|
| 21/tcp | FTP | vsftpd 3.0.5 | Moyen |
| 22/tcp | SSH | OpenSSH 10.0p2 | Faible |
| 30/tcp | Non attribué | Apache httpd 2.4.66 | ⚠ Élevé |
| 80/tcp | HTTP | Telnet | 🚨 Critique |
| 110/tcp | POP3 | Dovecot pop3d | Moyen |
| 139/tcp | NetBIOS | Samba smbd 4 | Moyen |
| 143/tcp | IMAP | Dovecot imapd | Moyen |
| 445/tcp | SMB | Samba smbd 4 | Moyen |

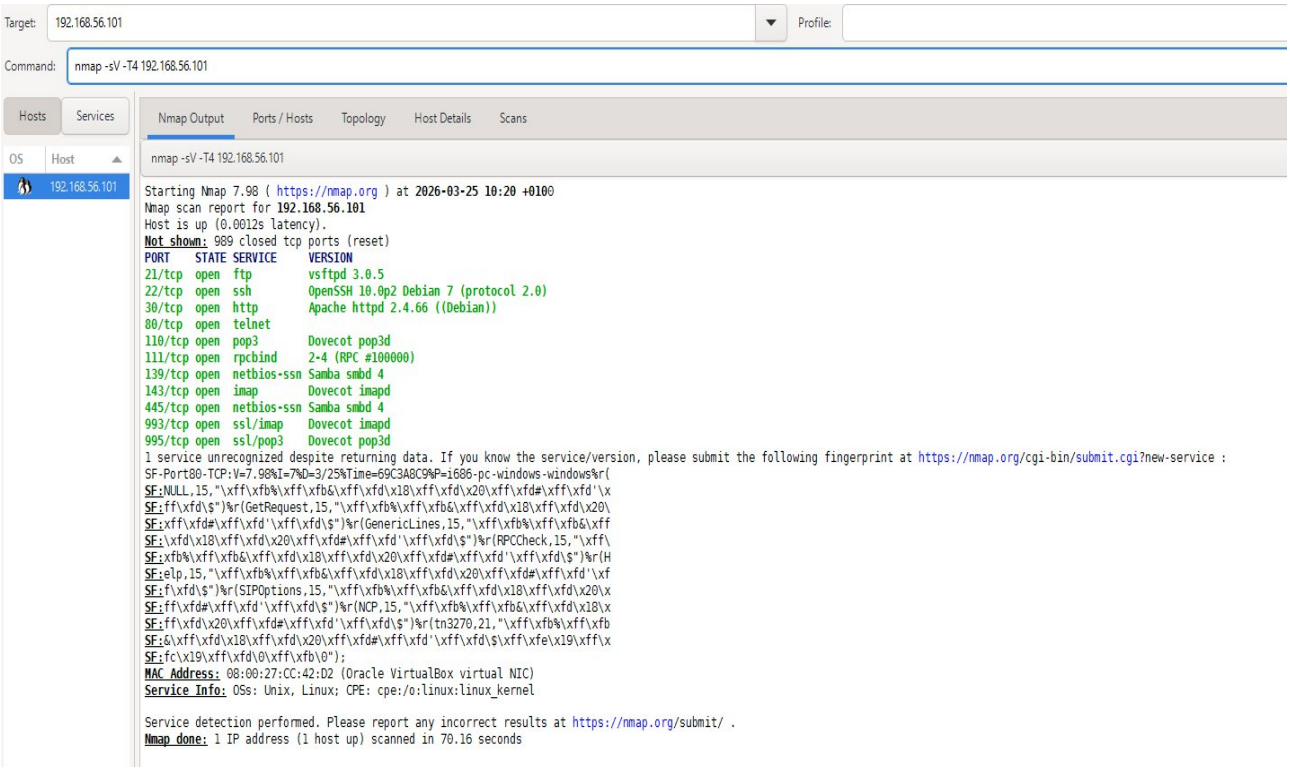
# Partie II - Audit Profond (6 pts)

## 2.1 - Objectif

L'énumération réseau est la clé pour lever le voile sur la sécurité par l'obscurité. L'objectif est de démasquer la véritable identité des services dissimulés sur des ports non standard.

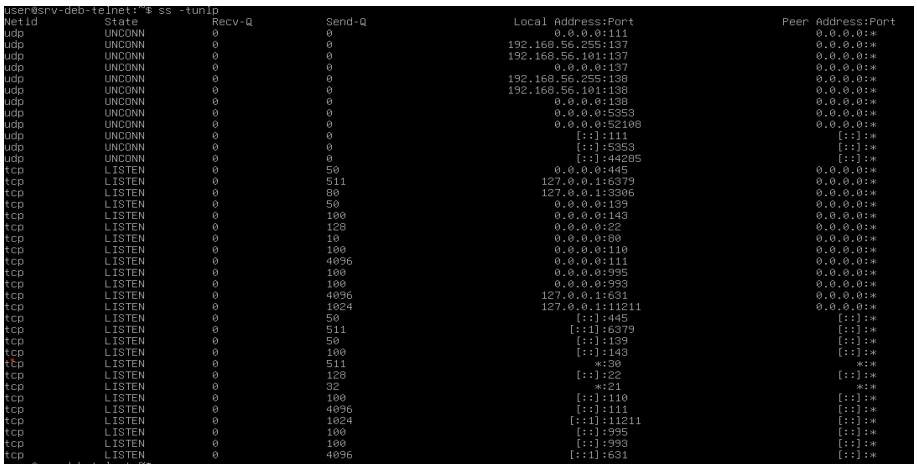
## 2.2 - Outil utilisé : Nmap (scan de version)

L'outil Nmap avec le flag -sV est utilisé pour interroger chaque port et identifier le service réel.




```
nmap -sV -T4 192.168.56.101
```

## 2.3 - Résultat du scan Nmap



*Deux anomalies majeures : le port 30 héberge Apache HTTP (standard : 80/443) et le port 80 héberge Telnet (standard : 23).*

### 2.4 - Confirmation avec Netcat

```
nc -v 192.168.56.101 30
curl http://192.168.56.101:30
```

✓ **Résultat :** *La réponse "Apache2 Debian Default Page - It works!" confirme formellement qu'un serveur web Apache 2.4.66 tourne sur le port 30.*

## Partie III - Analyse et Veille (4 pts)

### 3.1 - Service critique : Telnet sur le port 80

Le service le plus dangereux identifié est Telnet tournant sur le port 80. Cette configuration présente plusieurs risques critiques :

- ① Transmission en clair : Telnet transmet toutes les données sans chiffrement. Toute écoute réseau (sniffing) permet la capture immédiate des credentials.
- ② Contournement des pare-feux : En utilisant le port 80 (trafic HTTP standard), Telnet échappe aux règles de filtrage classiques.
- ③ Discrétion malveillante : Un attaquant peut utiliser ce canal pour maintenir un accès persistant sans alerter les IDS.

### 3.2 - Service à risque : Apache sur port non standard (30)

- ① Invisibilité aux scans basiques : Les scanners ne vérifiant que le port 80/443 ne détecteront pas ce serveur web.
- ② Surface d'attaque élargie : Un serveur web non surveillé peut exposer des fichiers sensibles ou servir de point d'entrée.

### 3.3 - Sources documentaires

| | |
|---|---|
| **ANSSI** | **Guide Hygiène Informatique - Règle 15 : Chiffrer les communications sensibles** |
| **OWASP** | **A02:2021 - Cryptographic Failures - Utilisation de protocoles non chiffrés** |
| **CVE MITRE** | **CWE-312 : Cleartext Storage / CWE-319 : Cleartext Transmission** |
| **RFC 854** | **Telnet Protocol Specification - protocole conçu sans sécurité (1983)** |

# Partie IV - Remédiation (6 pts)

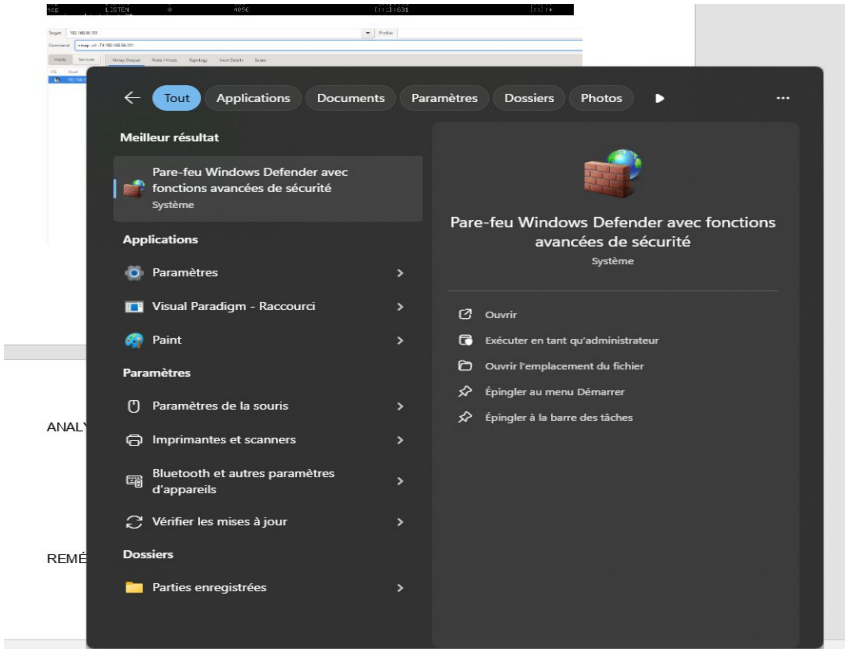
## 4.1 - Stratégie de remédiation

N'ayant pas les droits root sur la VM cible, la remédiation est appliquée au niveau du pare-feu Windows de la machine hôte. L'objectif est de bloquer les connexions sortantes vers le port 80 (Telnet) de la VM cible.

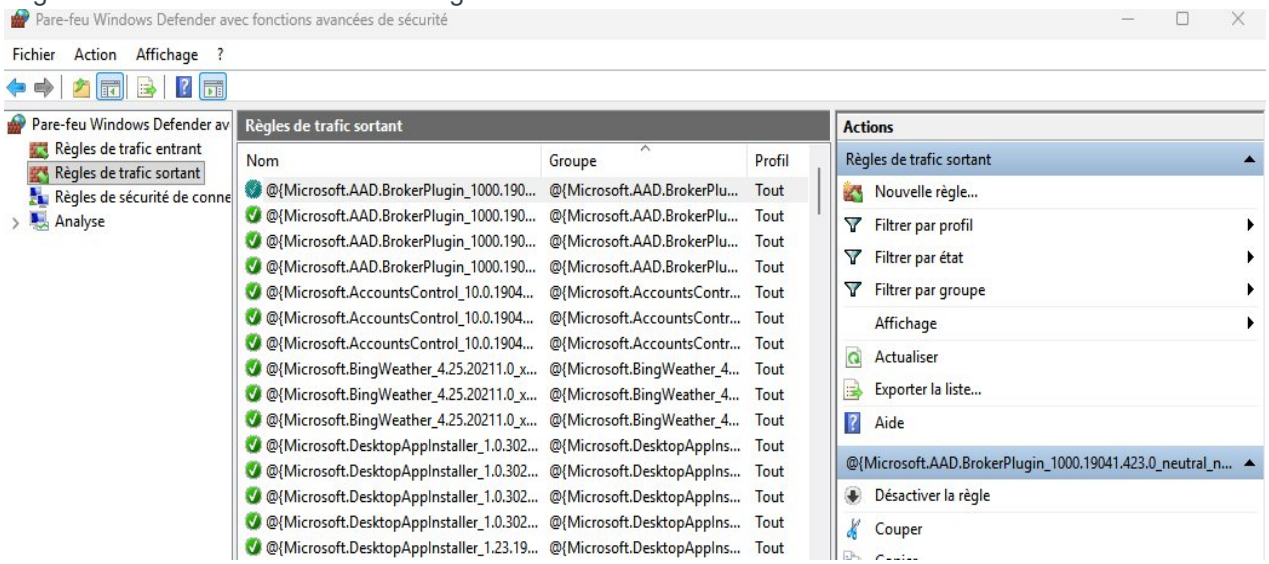
## 4.2 - Configuration du pare-feu Windows

Création d'une règle de trafic sortant dans Windows Defender Firewall avec fonctions avancées :

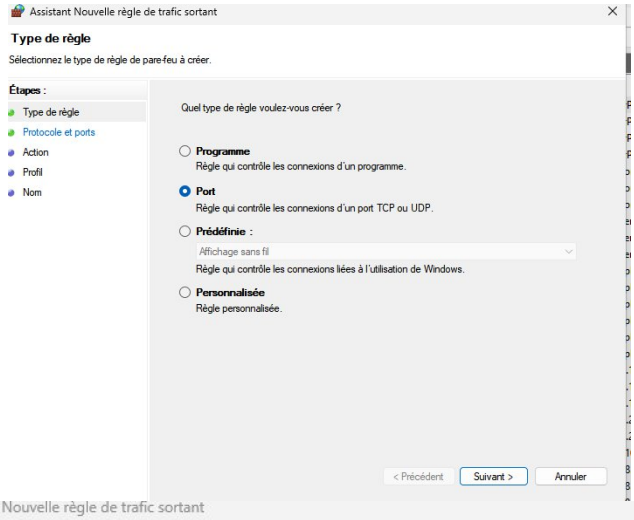
1. Ouvrir Pare-feu Windows Defender → Paramètres avancés

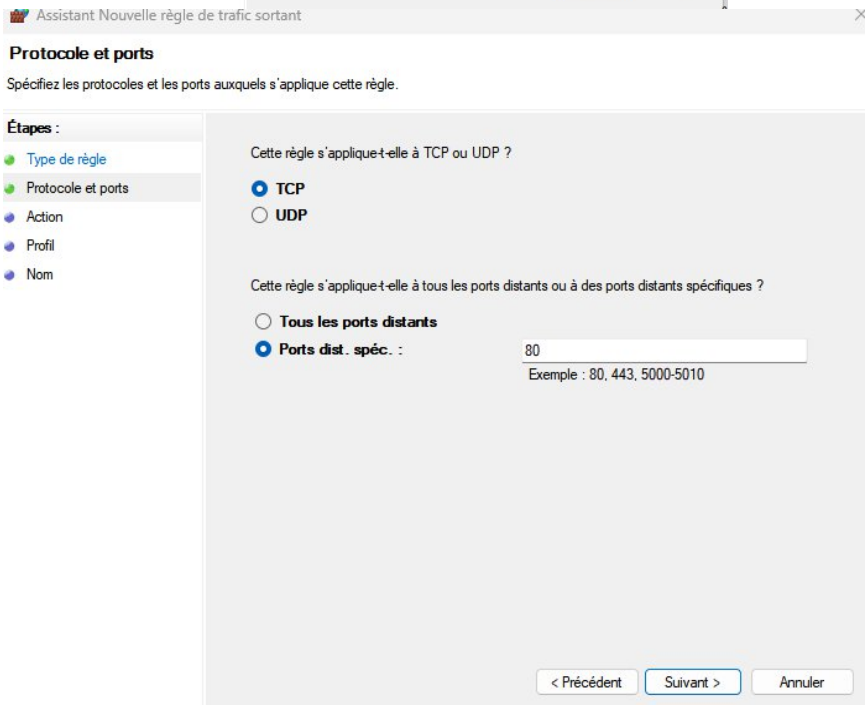



2. Règles de trafic sortant → Nouvelle règle

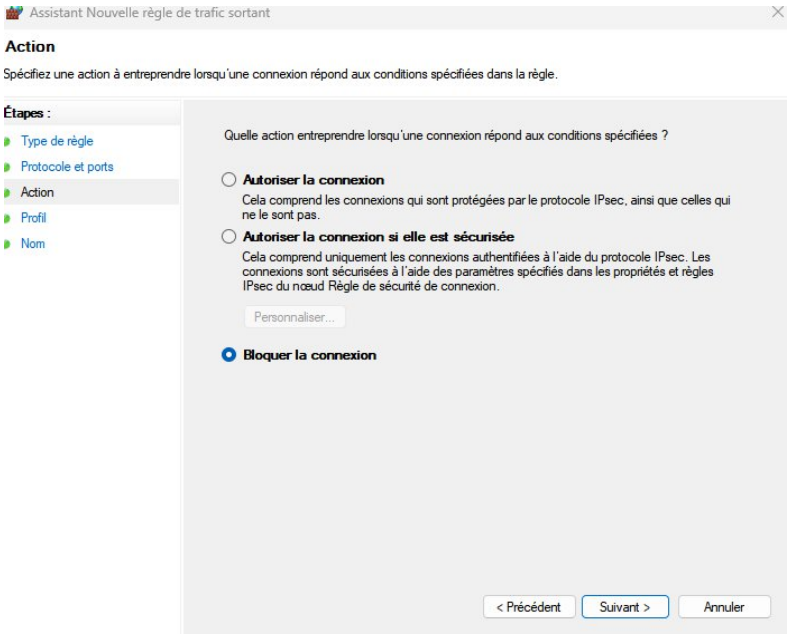


**3.** Type : Port → TCP → Port 80

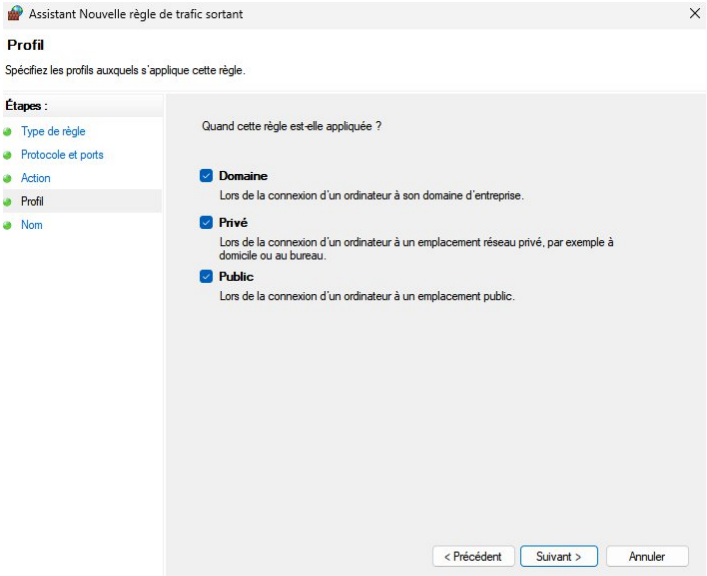


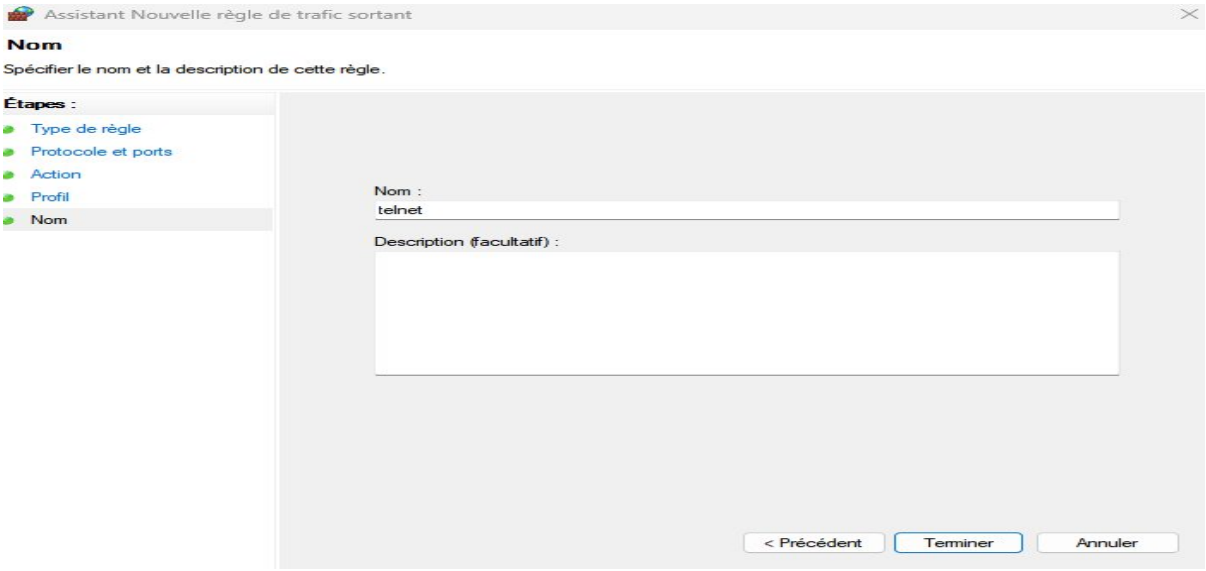

**4.** Action : Bloquer la connexion



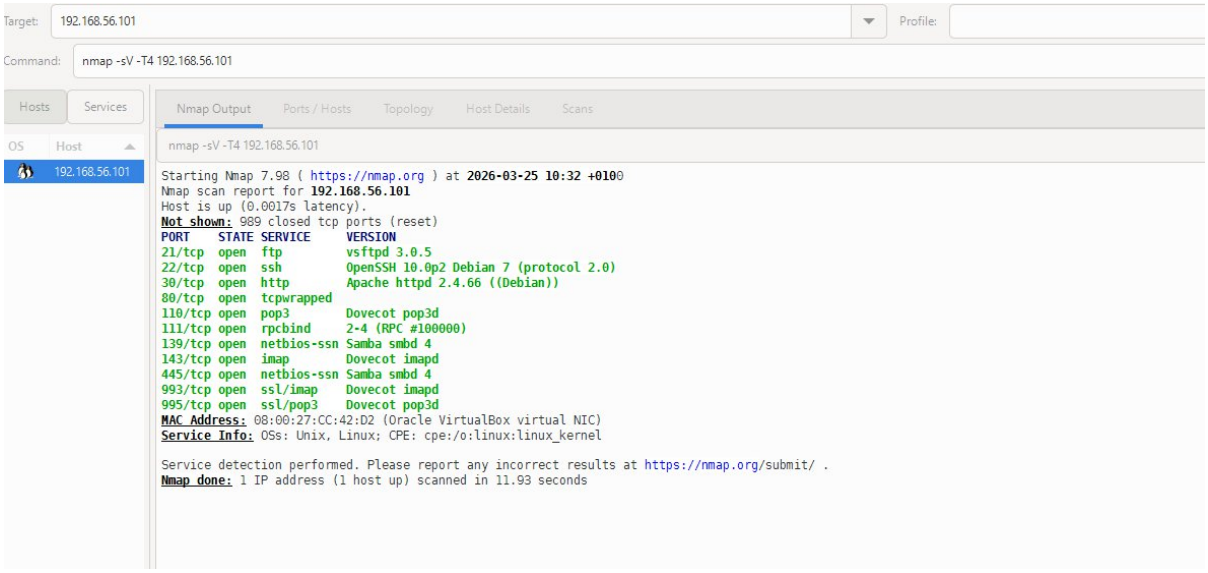

**5.** Profils : Domaine, Privé, Public (tous cochés)




**6.** Nom : Blocage Telnet port 80


Assistant Nouvelle règle de trafic sortant
Nom
Spécifier le nom et la description de cette règle.
Étapes :
Type de règle
Protocole et ports
Action
Profil
Nom
Nom :
telnet
Description (facultatif) :
< Précédent
Terminer
Annuler

## 4.3 - Validation par Nmap après blocage




✓ **Résultat :** *Le port 80 n'apparaît désormais plus dans les résultats Nmap. La connexion Telnet sur ce port est bloquée avec succès.*

## 4.4 - Recommandations complémentaires

- Remplacer Telnet par SSH (port 22) pour tout accès distant - protocole chiffré
- Reconfigurer Apache pour écouter sur le port 443 (HTTPS) avec un certificat SSL/TLS
- Mettre en place une règle firewall permanente sur la VM pour bloquer tout accès au port 30 et 80/Telnet
- Réaliser un audit régulier des ports exposés avec nmap -sV pour détecter toute anomalie

*Mission d'audit réseau complétée - Infrastructure analysée et sécurisée.*

*- Fin de la documentation -*